

Vulnerabilities & Threats that Matter

September 2022

Top 5 Takeaways

#1

In September, three vulnerabilities remained **unpatched**. Two of them were **Microsoft's ProxyNotShell**(CVE-2022-41040, CVE-2022-41082) and the third one(CVE-2022-3180) affected the **WordPress** plugin

#2

The **Albanian** Government was highly targeted by multiple **Iranian** attackers.

#3

After 10 months of being patched, **Log4j**(CVE-2021-44228) was still seen exploited by **Monti Ransomware**

#4

Lazarus was seen deploying a new tool **MagicRAT**.

#5

Kinsing malware was seen exploiting **two-year-old** vulnerabilities(CVE-2020-14882, CVE-2020-14883) in **Oracle**.

Vulnerabilities of the Month	Threat Actors of the Month	Malware of the Month	Top Targeted Countries	Top Targeted Industries	Common MITRE ATT&CK TTPs
					
46	10	7	Saudi Arabia USA Turkey Australia UK	Government Financial Manufacturing Education Telecommunications	160

Detailed Report

⚙️ Vulnerabilities of the Month

VENDOR	CVE	PATCH DETAILS
	CVE-2022-3038 CVE-2022-3039 CVE-2022-3040 CVE-2022-3041 CVE-2022-3042 CVE-2022-3043 CVE-2022-3044 CVE-2022-3045 CVE-2022-3046 CVE-2022-3071 CVE-2022-3075*	Update Google Chrome to version 105.0.5195.102 for Windows, Mac, and Linux https://www.google.com/intl/en/chrome/?standalone=1
	CVE-2022-32917* CVE-2022-32894* CVE-2022-32902 CVE-2022-32854 CVE-2022-32896 CVE-2022-32911 CVE-2022-32864 CVE-2022-32883 CVE-2022-32908 CVE-2022-32900	Upgrade to macOS Big Sur 11.7 and macOS Monterey 12.6
	CVE-2022-31474* CVE-2022-3180*	https://ithemes.com/blog/wordpress-vulnerability-report-special-edition-september-6-2022-backupbuddy/ Note: CVE-2022-3180: Patch is unavailable
	CVE-2022- 40139* CVE-2022-40140 CVE-2022-40141 CVE-2022-40142 CVE-2022-40143 CVE-2022-40144	https://files.trendmicro.com/products/Apex%20One/apexone_sp1_win_en_gm_b11092.exe
	CVE-2022-3236*	Upgrade to Sophos Firewall v18.5 MR5 (18.5.5), v19.0 MR2 (19.0.2), and v19.5 GA
	CVE-2020-14882 CVE-2020-14883	https://www.oracle.com/security-alerts/cpuoct2020.html

VENDOR	CVE	PATCH DETAILS
	CVE-2022-37969* CVE-2022-34718 CVE-2022-34721 CVE-2022-34722 CVE-2022-35805 CVE-2022-34700 CVE-2022-37957 CVE-2022-35803 CVE-2022-37954 CVE-2022-34725 CVE-2022-34729 CVE-2022-37972* CVE-2022-41040* CVE-2022-41082*	https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37969 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34718 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34721 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34722 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-35805 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34700 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37957 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-35803 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37954 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34725 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-34729 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37972 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41040 https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41082 Note: CVE-2022-41040 & CVE-2022-41082 Patch is unavailable

*zero-day vulnerability

Threat Actors of the Month

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 APT 40 (Temp.Periscope, Leviathan, KRYPTONITE PANDA, TEMP.Jumper, Bronze Mohawk, Mudcarp, Gadolinium, ATK 29, ITG09) 	China MOTIVE Information theft and espionage CVEs	Biomedical, Defense, Education, Government, Legal, Maritime, Technology, Engineering, Manufacturing, Research, Transportation	Belgium, Cambodia, Germany, Hong Kong, Malaysia, Norway, Philippines, Saudi Arabia, Switzerland, USA, UK, Australia.

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Worok 	Unknown	Energy, Financial, Bank, Maritime, Government, Public Sector and Telecommunications	Akrotiri and Dhekelia, Bahrain, Cyprus, Egypt, Iran, Iraq, Israel, Jordan, Kuwait, Lebanon, Oman, Palestine, Qatar, Saudi Arabia, Syria, Turkey, United Arab Emirates, Yemen, China, Hong Kong, Macau, Japan, Mongolia, North Korea, South Korea, Taiwan, BruneiCambodia, East Timor, Indonesia, Laos, Malaysia, Myanmar, Philippines, Singapore, Thailand, Vietnam, Kazakhstan, Kyrgyzstan, Tajikistan, Uzbekistan, South Africa
	MOTIVE		
	Information theft and espionage		
	CVEs		
	CVE-2021-34523		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Lazarus Group (LabyrinthChollima, Group77, Hastati Group, Whois Hacking Team,New RomanicCyber ArmyTeam,Zinc,HiddenCobra,Appl eworm, APT-C-26,ATK3,SectorA 01,ITG03) 	North Korea	Aerospace, Defense, Engineering, Financial, Government, Media, Shipping and Logistics, Technology and Cryptocurrencies	Australia, Bangladesh, Brazil, Canada, Chile, China, Ecuador, France, Germany, Guatemala, Hong Kong, India, Israel, Japan, Mexico, Philippines, Poland, Russia, South Africa, South Korea, Taiwan, Thailand, UK, USA, Vietnam
	MOTIVE		
	Information theft and espionage, Sabotage and destruction, Financial crime		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 APT 42 	MOTIVE	Education, Governments, Healthcare, Legal, professional services, Manufacturing, Media, Pharmaceuticals	Australia, USA, Ukraine, France, Spain, Sweden, Norway, Germany, Finland, Poland, Italy, UK, Romania, Belarus, Kazakhstan, Greece, Bulgaria, Iceland, Hungary, Portugal, Serbia, Austria, Czechia, Ireland, Lithuania, Latvia, Croatia, Bosnia and Herzegovina, Slovakia, Estonia, Denmark, Switzerland, Netherlands, Moldova, Belgium, Albania, North Macedonia, Turkey, Slovenia, Montenegro, Kosovo, Azerbaijan, Georgia, Luxembourg, Andorra, Malta, Liechtenstein, San Marino, Monaco, Vatican City, Cyprus, Armenia, Akrotiri, and Dhekelia, Bahrain, Cyprus, Egypt, Iran, Iraq, Israel, Jordan, Kuwait, Lebanon, Oman, Palestine, Qatar, Saudi Arabia, Syria, Turkey, UAE, Yemen
	Iran		
	Information theft and espionage		
	CVEs		

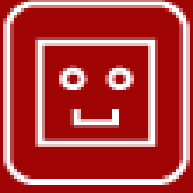
NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 DEV-0842 	MOTIVE	Financial Services, Government, Professional Services, Telecommunications	Albania, Israel, Jordan, Kuwait, Saudi Arabia, Turkey, and UAE
	Iran		
	Financial gain, Information theft and espionage		
	CVEs		
	CVE-2019-0604 CVE-2021-26855		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 DEV-0861 	Iran	Financial Services, Government, Professional Services, Telecommunications	Albania, Israel, Jordan, Kuwait, Saudi Arabia, Turkey, and UAE
	MOTIVE		
	Financial gain, Information theft and espionage		
	CVEs		
	CVE-2019-0604 CVE-2021-26855		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 DEV-0166 	Iran	Financial Services, Government, Professional Services, Telecommunications	Albania, Israel, Jordan, Kuwait, Saudi Arabia, Turkey, and UAE
	MOTIVE		
	Financial gain, Information theft and espionage		
	CVEs		
	CVE-2019-0604 CVE-2021-26855		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 DEV-0133 	Iran	Financial Services, Government, Professional Services, Telecommunications	Albania, Israel, Jordan, Kuwait, Saudi Arabia, Turkey, and UAE
	MOTIVE		
	Financial gain, Information theft and espionage		
	CVEs		
	CVE-2019-0604 CVE-2021-26855		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 SparklingGoblin (APT 41,Double Dragon,TG-2633, Bronze Atlas,Red Kelpie,Blackfly, Earth Baku,Grayfly)↗	China	Construction, Defense, Education, Energy, Financial, Government, Healthcare, High-Tech, Hospitality, Manufacturing, Media, Oil and gas, Petrochemical, Pharmaceutical, Retail, Telecommunications, Transportation, gaming.	Australia, Bahrain, Brazil, Canada, Chile, Denmark, Finland, France, Georgia, Hong Kong, India, Indonesia, Italy, Japan, Malaysia, Mexico, Myanmar, Netherlands, Pakistan, Philippines, Poland, Qatar, Saudi Arabia, Singapore, South Korea, South Africa, Sweden, Switzerland, Taiwan, Thailand, Turkey, UAE, UK, USA, Vietnam.
	MOTIVE		
	Financial crime, Information theft and espionage		
	CVEs		

NAME	ORIGIN	TARGET INDUSTRIES	TARGET COUNTRIES
 Vice Society ↗	Unknown	Construction, Education, Entertainment, Financial Services, Government, Healthcare, Hospitality, Insurance, Professional Services, Manufacturing, Retail, Utilities, Hotels, Pharmaceuticals, Telecommunications	Argentina, Austria, Australia, Antigua and Barbuda,Brazil, Canada, Colombia, France, Germany, Greece, Indonesia, Ireland, Italy, Malaysia, New Zealand, Netherlands, Saudi Arabia, Spain, Sweden, Thailand, United Kingdom, United States
	MOTIVE		
	Financial Gain		
	CVEs		
	CVE-2021-1675 CVE-2021-34527		



Malware of the Month

NAME	OVERVIEW	TYPE	DELIVERY METHOD
<u>Moisha</u> 	Moisha ransomware is based on .Net and was developed to carry out very targeted attacks, as indicated by its ransom note. The threat actor uses double-extortion techniques to encrypt and exfiltrate victim data.	Ransomware	phishing or using social engineering methods
<u>RedAlert</u> 	RedAlert ransomware aka N13V attack disrupted the operations and online services of a government agency in Chile. In a classic double-extortion manner, the malware targeted the agency to encrypt the documents	Ransomware	Vulnerable Microsoft and VMware ESXi servers
<u>CodeRAT</u> 	CodeRAT allows attackers to monitor the victim's activity and has broad monitoring capabilities that support approximately 50 commands. These capabilities are aimed at webmail, databases, Microsoft Office documents, social media platforms, and Windows.	Remote Access Trojan	Word document with Microsoft Dynamic Data Exchange (DDE) exploit
<u>MagicRAT</u> 	MagicRAT creates scheduled tasks on compromised systems to achieve persistence. Additionally, it gives the attacker a remote shell to execute arbitrary commands and manipulate files.	Remote Access Trojan	Vulnerable VMware Horizon servers
<u>Monti</u> 	The ransomware payload dropped after the initial infection is a 32-bit Windows executable named "locker.exe." Upon execution, the ransomware encrypts files on a disc, adds a ".PUUUK" extension to encrypted file names, and produces the ransom note.	Ransomware	VMware Horizon Vulnerable to Log4Shell (CVE-2021-44228)

NAME	OVERVIEW	TYPE	DELIVERY METHOD
SideWalk 	SideWalk is a multifunctional backdoor that can load other modules from the command-and-control server. It employs Google Docs as a dead-drop resolver and Cloudflare workers as its command and control (C2) server. The malware runs five threads simultaneously in order to complete a single task.	Backdoor	Unkown
Kinsing 	Kinsing malware which is responsible for cryptomining and sending data to the attacker's C2 channel.	Malware	Oracle WebLogic Server vulnerable to CVE-2020-14882, CVE-2020-14883

Targeted Countries



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

Targeted Industries



Common MITRE ATT&CK TTPs

TA0043: Reconnaissance	TA0042: Resource Development	TA0001: Initial Access	TA0002: Execution	TA0003: Persistence	TA0004: Privilege Escalation	TA0005: Defence Evasion
T1589: Gather Victim Identity Information	T1586: Compromise Accounts	T1189: Drive-by Compromise	T1059: Command and Scripting Interpreter	T1098: Account Manipulation	T1548: Abuse Elevation Control Mechanism	T1134: Access Token Manipulation
T1592: Gather Victim Host Information	T1586.002: Email Accounts	T1190: Exploit Public-Facing Application	T1059.001: PowerShell	T1098.002: Additional Email Delegate Permissions	T1134: Access Token Manipulation	T1140: Deobfuscate/Decode Files or Information
T1592.001: Hardware	T1587: Develop Capabilities	T1133: External Remote Services	T1059.005: Visual Basic	T1547: Boot or Logon Autostart Execution	T1547: Boot or Logon Autostart Execution	T1574: Hijack Execution Flow
T1592.002: Software	T1587.001: Malware	T1566: Phishing	T1059.007: JavaScript	T1547.002: Authentication Package	T1547.001: Registry Run Keys / Startup Folder	T1574.001: DLL Search Order Hijacking
T1590: Gather Victim Network Information	T1587.003: Digital Certificates	T1566.001: Spearphishing Attachment	T1059.004: Unix Shell	T1547.004: Winlogon Helper DLL	T1547.002: Authentication Package	T1574.007: Path Interception by PATH Environment Variable
T1590.005: IP Addresses	T1588: Obtain Capabilities	T1566.002: Spearphishing Link	T1059.003: Windows Command Shell	T1547.001: Registry Run Keys / Startup Folder	T1547.004: Winlogon Helper DLL	T1562: Impair Defenses
T1598.003: Spearphishing Link	T1588.004: Digital Certificates	T1566.003: Spearphishing via Service	T1203: Exploitation for Client Execution	T1136: Create Account	T1543: Create or Modify System Process	T1562.004: Disable or Modify System Firewall
T1594: Search Victim-Owned Websites	T1588.005: Exploits	T1195: Supply Chain Compromise	T1106: Native API	T1136.001: Local Account	T1543.003: Windows Service	T1562.008: Disable Cloud Logs
	T1588.001: Malware	T1078: Valid Accounts	T1053: Scheduled Task/Job	T1136.002: Domain Account	T1546: Event Triggered Execution	T1070: Indicator Removal on Host
	T1588.002: Tool		T1053.003: Cron	T1543: Create or Modify System Process	T1068: Exploitation for Privilege Escalation	T1070.002: Clear Linux or Mac System Logs
	T1588.006: Vulnerabilities		T1053.005: Scheduled Task	T1543.003: Windows Service	T1574: Hijack Execution Flow	T1070.004: File Deletion
	T1583: Acquire Infrastructure		T1569: System Services	T1546: Event Triggered Execution	T1574.001: DLL Search Order Hijacking	T1036: Masquerading
	T1583.001: Domains		T1569.002: Service Execution	T1133: External Remote Services	T1574.007: Path Interception by PATH Environment Variable	T1036.001: Invalid Code Signature
	T1583.004: Server		T1204: User Execution	T1574: Hijack Execution Flow	T1055: Process Injection	T1036.005: Match Legitimate Name or Location
	T1583.003: Virtual Private Server		T1204.002: Malicious File	T1574.001: DLL Search Order Hijacking	T1053: Scheduled Task/Job	T1112: Modify Registry
	T1584: Compromise Infrastructure		T1204.001: Malicious Link	T1574.007: Path Interception by PATH Environment Variable	T1053.003: Cron	T1027: Obfuscated Files or Information
			T1559: Inter-Process Communication	T1053: Scheduled Task/Job	T1053.005: Scheduled Task	T1027.002: Software Packing
			T1047: Windows Management Instrumentation			T1055: Process Injection
				T1053.003: Cron	T1078: Valid Accounts	
				T1053.005: Scheduled Task		T1553: Subvert Trust Controls
				T1505: Server Software Component		T1218: System Binary Proxy Execution
				T1078: Valid Accounts		T1127: Trusted Developer Utilities Proxy Execution
				T1505: Server Software Component		T1078: Valid Accounts
				T1505.003: Web Shell		T1497: Virtualization/Sandbox Evasion
						T1548: Abuse Elevation Control Mechanism
						T1222: File and Directory Permissions Modification
						T1222.002: Linux and Mac File and Directory Permissions Modification
						T1564: Hide Artifacts
						T1564.001: Hidden Files and Directories
						T1620: Reflective Code Loading

TA0006: Credential Access	TA0007: Discovery	TA0008: Lateral Movement	TA0009: Collection	TA0011: Command and Control	TA0040: Impact
T1555: Credentials from Password Stores	T1087: Account Discovery	T1210: Exploitation of Remote Services	T1560: Archive Collected Data	T1071: Application Layer Protocol	T1485: Data Destruction
T1056: Input Capture	T1083: File and Directory Discovery	T1021: Remote Services	T1560.001: Archive via Utility	T1071.001: Web Protocols	T1486: Data Encrypted for Impact
T1003: OS Credential Dumping	T1120: Peripheral Device Discovery	T1570: Lateral Tool Transfer	T1560.002: Archive via Library	T1071.002: File Transfer Protocols	T1490: Inhibit System Recovery
T1557: Adversary-in-the-Middle	T1057: Process Discovery	T1080: Taint Shared Content	T1005: Data from Local System	T1573: Encrypted Channel	T1496: Resource Hijacking
T1187: Forced Authentication	T1012: Query Registry		T1056: Input Capture	T1573.002: Asymmetric Cryptography	T1489: Service Stop
T1552: Unsecured Credentials	T1518: Software Discovery		T1113: Screen Capture	T1105: Ingress Tool Transfer	T1531: Account Access Removal
T1552.001: Credentials In Files	T1082: System Information Discovery		T1557: Adversary-in-the-Middle	T1095: Non-Application Layer Protocol	T1565: Data Manipulation
T1552.004: Private Keys	T1016: System Network Configuration Discovery		T1530: Data from Cloud Storage Object	T1090: Proxy	T1565.001: Stored Data Manipulation
	T1049: System Network Connections Discovery		T1025: Data from Removable Media	T1102: Web Service	T1499: Endpoint Denial of Service
	T1497: Virtualization/Sandbox Evasion		T1125: Video Capture	T1071: Application Layer Protocol	
	T1046: Network Service Discovery			T1132: Data Encoding	
	T1018: Remote System Discovery			T1132.001: Standard Encoding	
	T1124: System Time Discovery			T1573.001: Symmetric Cryptography	

Threat Advisories (September 2022)

MONDAY		TUESDAY		WEDNESDAY		THURSDAY		FRIDAY		SATURDAY		SUNDAY	
							1		2		3		4
						  							
	5		6		7		8		9		10		11
						 		 					
	12		13		14		15		16		17		18
		 		 		 		 					
	19		20		21		22		23		24		25
						  							
	26		27		28		29		30		31		
													

Click on any of the icons to get directed to the advisory

	Red Vulnerability Report
	Amber Vulnerability Report
	Green Vulnerability Report
	Red Attack Report
	Amber Attack Report
	Red Actor Report

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

October 16, 2022 • 11:55 PM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com